

LINEAMIENTOS DE CIBERSEGURIDAD PARA LA CADENA DE SUMINISTROS

Contenido

1. INTRODUCCIÓN	3
2. OBJETIVO	3
3. ALCANCE	3
4. ROLES Y RESPONSABILIDADES	4
5. LINEAMIENTOS PARA PROVEEDORES	5
5.1. Obligaciones de protección de datos y Ciberseguridad	5
5.1.1. Soluciones informáticas críticas y contratos que involucren el procesamiento y/o retención de alto volumen de datos personales	5
5.1.2. Soluciones informáticas y contratos en los cuales, el procesamiento y retención de datos personales no está relacionado con el servicio prestado	6
5.2. Ciberseguridad	6
5.3. Debida diligencia de Ciberseguridad	7
5.4. Contratos	8
6. GESTIÓN DE RELACIONES CON PROVEEDORES	9
6.1. Subcontratación	9
6.2. Acceso por parte del tercero a la información de la compañía	9
6.3. Monitoreo del acceso de los terceros a la red de la compañía	10
7. GESTIÓN DE INCIDENTES DE SEGURIDAD	10
8. NOTIFICACIÓN DE UNA VIOLACIÓN DE DATOS PERSONALES A LA COMPAÑÍA	11
9. INFRACCIONES A LOS LINEAMIENTOS	11
10. DOCUMENTACIÓN RELACIONADA	12
ANEXO A	12
ANEXO B	12
ANEXO C	12
ANEXO D	12
APROBADO POR	13
CONTROL DE VERSIÓN	13

AUDIENCIA

Estos lineamientos aplican a todos los aliados estratégicos que soporte procesos que tengan relación con GRUPO ARGOS S.A. y sus compañías vinculadas (ARGOS, ARGOS USA, CELSIA, ODINSA Y SUMMA).

1. INTRODUCCIÓN

GRUPO ARGOS S.A. y sus compañías vinculadas (ARGOS, ARGOS USA, CELSIA, ODINSA Y SUMMA) en adelante la compañía, confía en la integridad y exactitud de su información para llevar a cabo sus actividades y obligaciones con sus clientes y partes interesadas. Dado lo anterior, es esencial que la información esté protegida de acuerdo con las mejores prácticas profesionales, incluidos los requisitos legales, reglamentarios y contractuales que mantienen la confidencialidad, integridad y disponibilidad de todos los activos de información.

2. OBJETIVO

Establecer lineamientos para garantizar que los contratos y las transacciones entre la compañía y los proveedores externos, tengan niveles aceptables de protección de datos y Ciberseguridad para proteger los datos confidenciales tanto personales como comerciales.

3. ALCANCE

El alcance de estos lineamientos se aplica a contratos, acuerdos de servicios y otros documentos contractuales que involucren soluciones de TI/TO o la prestación de servicios que requieran acceso o procesamiento de datos personales¹ y/o comerciales confidenciales para la entrega y/o soporte de los servicios y actividades comerciales de la compañía.

A continuación, se describen los diferentes tipos de proveedores que se pueden tener en la cadena de suministro:

¹ **Procesamiento de datos personales:** Se refiere al almacenamiento, manejo, procesamiento o retención de datos, incluidos los datos personales relacionados con la información de la compañía (Ej.: Registros de empleados, proveedores y clientes) Los ejemplos incluyen, entre otros, la adquisición de soluciones y prestación de servicios de TI.

Tipo de proveedor	Función
Fabricante	- Diseñar, desarrollar, fabricar y entregar productos y componentes a sus clientes. - Fuente de componentes de hardware y software en su cadena de suministro. - Entregar productos que puedan servir para múltiples propósitos; es decir, se venden productos similares a diferentes usuarios de productos con diferentes escenarios de uso.
Integradores de sistemas (proveedores de servicios de ingeniería)	- Sistemas de ingeniería que se utilizan en entornos de producción. - Diseñar e implementar sistemas y/o soluciones de automatización utilizadas en industrias e infraestructura crítica. - Puede incluir obra civil como despliegue de infraestructura de red. - Desempeñar un papel esencial en el diseño y la implementación de la ciberseguridad en la infraestructura (crítica).
Gestión de servicios TIC (Tecnología de la información y las comunicaciones)	- Proveedores de servicios gestionados (MSP): Presta servicios relacionados con la instalación, gestión, operación o mantenimiento de productos TIC, redes, infraestructuras, aplicaciones o cualquier otra red y sistemas de información, mediante la asistencia o administración activa realizada en las instalaciones del cliente o a distancia. - Proveedores de servicios de seguridad gestionados (MSSP): Ayuda a las organizaciones en áreas tales como respuesta a incidentes, pruebas de penetración, auditorías de seguridad y consultoría. Ofrece servicios, tales como: - Evaluación – Pruebas de penetración o conformidad con requisitos o estándares de seguridad específicos; - Implementación – Implementación de controles de seguridad como detección de malware en una infraestructura; - Gestión – Servicios de centro operativo de seguridad (SOC) para respuesta a incidentes.
Proveedores de servicios digitales	Los servicios de computación en la nube incluyen: - Infraestructura como un servicio (IaaS) - Plataforma como servicio (PaaS) - Software como servicio (SaaS) - Infraestructura de red como servicio (NaaS)

4. ROLES Y RESPONSABILIDADES

Abastecimiento: Asegurar la integridad y confiabilidad de los proveedores como asociados de negocio en la cadena de abastecimiento.

Ciberseguridad: Dar lineamientos y validación de criterios de Ciberseguridad y protección de datos personales para protección de la integridad, disponibilidad y confidencialidad en los productos y servicios de TI o TO suministrados por terceros.

Asuntos corporativos: Aseguramiento contractual de los requisitos de cumplimiento por parte de los terceros de TI, frente a las prácticas de Ciberseguridad y protección de datos personales, definidos por la compañía.

5. LINEAMIENTOS PARA PROVEEDORES

5.1. Obligaciones de protección de datos y Ciberseguridad

La Ciberseguridad es fundamental en la compañía para el cumplimiento con la regulación de protección de datos y un enfoque clave en su estrategia de gestión, adquisición y evaluación de riesgos.

La compañía utiliza un enfoque basado en el riesgo sobre cómo deben protegerse los activos de información. Tener procesos de adquisición que se alineen con los riesgos de activos de información identificados, ayuda a garantizar que se adquieran servicios y soluciones de TI / TO que pueden proporcionar el nivel y la calidad de Ciberseguridad requeridos por la compañía y cumplen con la regulación actual de protección de datos. Para evaluar el nivel de riesgo, todos los proyectos que impliquen la recopilación, el procesamiento o el almacenamiento de datos personales deben estar respaldados por la realización de una evaluación de impacto de la protección de datos. Se debe realizar esta evaluación para todos los proyectos nuevos y realizar revisiones pertinentes en proyectos existentes. Cuando corresponda, la compañía identificará la necesidad de una evaluación en una etapa temprana y la integrará en la gestión de proyectos u otros procesos comerciales.

Se han desarrollado dos enfoques de adquisición para su uso en los contratos de adquisición y servicios, que incluyen datos personales y comerciales confidenciales. El uso de estos enfoques está dado por la naturaleza del servicio y la sensibilidad, el volumen y el riesgo asociado con la información administrada o accedida.

5.1.1. Soluciones informáticas críticas y contratos que involucren el procesamiento y/o retención de alto volumen de datos personales

Cuando el contrato implique la adquisición de una solución de TI o un servicio que, en parte, dependa de una solución de TI para procesar datos personales, la adquisición se evaluará con respecto a las normas de protección de datos vigentes para determinar el nivel asociado de riesgo percibido para la compañía. El tipo de datos personales dará lugar a una de tres clasificaciones; Datos Sensibles, Datos Privados o Datos Públicos.

La siguiente tabla proporciona orientación sobre la metodología de clasificación de la compañía. Esta también define los requisitos de Ciberseguridad y protección de datos que los proveedores potenciales deberán cumplir como parte del proceso de adquisición. Los requisitos individuales de Ciberseguridad y protección de datos se detallan en el Anexo A.

Tipo de datos personales		
Datos sensibles	Datos privados	Datos públicos
La solución o servicio implica el almacenamiento o procesamiento de categorías especiales de datos personales. ➤ Origen racial o étnico, ➤ Opiniones políticas, ➤ Creencias religiosas o filosóficas ➤ Afiliación sindical ➤ El procesamiento de datos genéticos, datos biométricos con el propósito de identificar de manera única a una persona física. ➤ Datos relativos a la salud. ➤ Datos relativos a la vida sexual o la orientación sexual de una persona física.	La solución o servicio implica el almacenamiento o procesamiento de información relacionada con una persona física identificada o identificable.	La solución o servicio tiene datos personales muy limitados o no implica el almacenamiento o procesamiento de ningún dato personal.

Nota: Si no se determina lo contrario, todas las nuevas soluciones y servicios de TI (Incluidas las mejoras significativas) que capturen, procesen o administren información financiera y comercial confidencial, serán clasificadas como “Datos privados”.

5.1.2. Soluciones informáticas y contratos en los cuales, el procesamiento y retención de datos personales no está relacionado con el servicio prestado

Cuando el almacenamiento, manejo, procesamiento y/o retención de datos confidenciales personales o comerciales no esté relacionado con el servicio que se brinda, se les pedirá a los terceros que cumplan con los requisitos enumerados en el Anexo B.

5.2. Ciberseguridad

A menos que pueda aplicar una exención, los contratos de la compañía para las soluciones críticas de TI / TO y los contratos que implican el procesamiento y/o la retención de un gran volumen de datos personales incluirán un requisito

contractual para que el proveedor esté certificado bajo una buena práctica de Ciberseguridad. Ej: Norma ISO27001:2022

Considerando especial atención en las siguientes cláusulas del anexo A de la norma:

- Ciberseguridad en las relaciones con los proveedores (5.19)
- Abordar la Ciberseguridad en los acuerdos con los proveedores (5.20)
- Gestión de la Ciberseguridad en la cadena de suministro TIC (5.21)
- Seguimiento, revisión y gestión de cambios de los servicios de los proveedores (5.22)
- Ciberseguridad para el uso de servicios en la nube (5.23)

También podría considerarse, dependiendo del servicio a prestar, que el tercero tome una póliza de ciberseguridad que le dé cobertura en caso de materializarse algún incidente de seguridad/ciberseguridad que comprometa los servicios ofrecidos a la compañía.

5.3. Debida diligencia de Ciberseguridad

En la medida de lo posible, se llevarán a cabo verificaciones de debida diligencia proporcionales al riesgo del procesamiento antes de que se acuerde un contrato con un tercero. El proceso de debida diligencia incluye comprobaciones de seguridad de datos, visitas a oficinas/centros de datos externos, pruebas de sistemas y trabajos de auditoría. Este proceso ayuda a la compañía a demostrar que se han implementado las medidas técnicas y organizativas adecuadas de acuerdo con los requisitos actuales de protección de datos.

En línea con lo anterior, los nuevos proyectos de sistemas de TI, los cambios significativos en los sistemas o servicios existentes categorizados como 'Sensibles' o 'Privados' anteriormente, deben notificarse al área de ciberseguridad para determinar el nivel de evaluación requerido.

El objetivo de la(s) visita(s) al sitio, será evaluar la idoneidad de los controles físicos, lógicos y operativos establecidos y evaluar si los procedimientos aprobados de Ciberseguridad y protección de datos del proveedor están integrados como parte de las operaciones diarias.

Al finalizar la debida diligencia de auditoría, los hallazgos de protección de datos y Ciberseguridad se comunicarán al proveedor para que realice sus comentarios. En este punto, el proveedor tiene la oportunidad de dar una respuesta sobre los hallazgos que se han identificado e incluir acciones apropiadas con respecto a cómo se abordará el control/debilidad (incluido un plazo para la corrección). Los detalles de los hallazgos de Ciberseguridad y la respuesta del proveedor se incluirán en el contrato (Si así se considera) para permitir el seguimiento de la implementación de los controles de Ciberseguridad acordados. En el Anexo C se incluye un diagrama de flujo que describe los pasos clave a seguir.

Se bloquean los derechos de acceso y cuentas de usuario a todos los colaboradores, contratistas y terceros, una vez se haya dado por finalizado las relaciones establecidas para prevenir los accesos posteriores a los procesos y sistemas de la organización.

A todos los funcionarios que cambien de rol, se les debe revisar el acceso a los sistemas, eliminándolo si es necesario. La información almacenada, procesada o transmitida por estos funcionarios en repositorios distintos a los oficiales de la compañía será borrada (Esto incluye la información almacenada en computadores personales, dispositivos móviles, sistemas de correo y colaboración).

El único impedimento para la destrucción de información es de orden legal y/o jurídico, el cual determinará el periodo mínimo de almacenamiento de la información (periodo de retención).

5.4. Contratos

Todos los contratos definirán claramente las responsabilidades de protección de datos y Ciberseguridad de cada parte hacia la otra, detallando las partes del contrato, la fecha de entrada en vigencia, las funciones o los servicios que se brindan (por ejemplo, niveles de servicio definidos), responsabilidades, limitaciones en el uso de subcontratistas y otros asuntos comerciales/legales normales a cualquier contrato. Dependiendo de la clasificación de los datos, se pueden incorporar varios controles de Ciberseguridad adicionales dentro del contrato además de los establecidos en el Anexo A o B dependiendo de la naturaleza de la prestación del servicio.

Para las actividades de cierre del contrato, los interventores de los contratos deben diligenciar las preguntas relacionadas en el Anexo D.

6. GESTIÓN DE RELACIONES CON PROVEEDORES

Durante la vigencia del contrato o vigencia de la relación, la compañía gestionará los acuerdos con sus terceros para asegurar que se mantengan los estándares de protección de datos y Ciberseguridad. Cuando se haya llevado a cabo una revisión de la Ciberseguridad, que dio como resultado que se hicieran recomendaciones al tercero, la implementación de estas debe monitorearse durante las reuniones de revisión del contrato.

6.1. Subcontratación

La compañía incluirá obligaciones contractuales apropiadas para garantizar que cualquier subcontratista contratado por un tercero externo, esté obligado a operar con los mismos estándares de protección de datos y Ciberseguridad que el contratista principal. Cuando haya un cambio en la entrega de un contrato con el contratista principal que busca subcontratar todo o parte del contrato, esto debe ser aprobado formalmente por la compañía antes de cualquier cambio.

6.2. Acceso por parte del tercero a la información de la compañía

La compañía permitirá que terceros accedan a su información y datos, cuando existan contratos formales y acuerdos de intercambio de datos de conformidad con la regulación vigente en materia de protección de datos, la política de ciberseguridad de la compañía y cuando:

- El acceso a la información es una parte acordada de la solución/servicio proporcionado.
- El procesamiento y la visualización de la información son necesarios para el mantenimiento y la resolución de problemas de la solución que se proporciona.
- Puede ser necesario reconstruir, reparar o reestructurar la información.
- Se ha proporcionado información para su inclusión en la solución/servicio por parte de la compañía.
- Es posible que la información deba transferirse a otros sistemas o durante las actualizaciones de la solución de TI.
- Es posible que sea necesario recopilar información con el acuerdo de la compañía y en su nombre.

La visualización (es decir, el acceso no aprobado por la compañía) de la información de la compañía no está permitida en ningún momento por parte de terceros. No se debe acceder a la información de la compañía bajo ninguna circunstancia a menos que se hayan establecido acuerdos formales de intercambio de información o permisos contractuales por escrito entre las partes que permitan que esto suceda.

El alcance de los requisitos de los proveedores externos para acceder a la información de la compañía deberá identificarse antes de establecer y celebrar cualquier obligación contractual. Las partes también deben acordar formalmente el nivel y el tipo de acceso a la información por parte de terceros. Los requisitos de seguridad para cada tipo de información se definirán en toda la documentación del contrato y la Ciberseguridad debe manejarse de acuerdo con la Política de ciberseguridad de la compañía.

La compañía tiene muy claro que cuando exista un requisito para el procesamiento de datos personales de colaboradores o usuarios de servicios por parte de terceros, la información debe ser tratada de acuerdo con las obligaciones y requisitos de protección de datos de la compañía para garantizar la confidencialidad, integridad y disponibilidad de toda la información.

6.3. Monitoreo del acceso de los terceros a la red de la compañía

Las soluciones de tecnológicas alojadas en la red de la compañía estarán sujetas a controles periódicos para garantizar que se controle cualquier acceso externo por parte de proveedores externos para soporte y mantenimiento. Una vez que el tercero haya realizado el trabajo requerido, se deshabilitará el acceso a la cuenta y se cambiará la contraseña. Cada instancia de conexiones de soporte y mantenimiento requeridas por el proveedor externo deberá ser aprobada formalmente por la compañía antes de ser proporcionada.:

7. GESTIÓN DE INCIDENTES DE SEGURIDAD

Los terceros deben contar con procedimientos de gestión de incidentes de seguridad adecuados, que correspondan al nivel de servicio que se brinda, la sensibilidad de los datos y los requisitos la política de ciberseguridad. El alcance de estas responsabilidades se especificará en el contrato o acuerdo de intercambio de datos. Los terceros deberán

notificar a la compañía sobre cualquier incidente de seguridad importante tan pronto como sea posible, a través de los medios que la compañía acuerde con el tercero.

8. NOTIFICACIÓN DE UNA VIOLACIÓN DE DATOS PERSONALES A LA COMPAÑÍA

Los terceros tienen el deber de comunicar cualquier violación de datos a la compañía. Una violación de datos personales significa una violación de la seguridad que conduce a la destrucción, pérdida, alteración, divulgación no autorizada o acceso a datos personales. Se requiere que una infracción se informe en el menor tiempo posible (Ej: Minutos o horas) a través del procedimiento de gestión de incidentes de la compañía. De lo contrario, podría resultar en multas significativas que se impondrán a la compañía.

9. INFRACCIONES A LOS LINEAMIENTOS

Las infracciones a estos lineamientos y/o los incidentes de seguridad pueden definirse como eventos que podrían tener, o han resultado en, pérdida o daño a los activos de información de la compañía, o un evento que infringe los procedimientos y políticas de seguridad de la compañía. Todos los proveedores externos contratados para brindar, respaldar o acceder a soluciones que permitan a la compañía llevar a cabo sus funciones comerciales y brindar sus servicios, tienen la responsabilidad de adherirse a la política de ciberseguridad, los presentes lineamientos y todos los requisitos de respaldo descritos y referenciados en la documentación formal y los acuerdos contractuales.

Todos los colaboradores tienen la responsabilidad de informar los incidentes de seguridad y las infracciones a la política de ciberseguridad y los presentes lineamientos dentro de las 24 horas posteriores a la toma de conocimiento del incidente a través del Procedimiento de gestión de Incidentes de la compañía.

El incumplimiento de la política de ciberseguridad y los presentes lineamientos por parte de proveedores, consultores o contratistas externos podría resultar en la eliminación inmediata del acceso a las soluciones de TI, la suspensión o cancelación de los acuerdos contractuales. Si el incumplimiento causa daño o el compromiso de las soluciones tecnológicas de la compañía o la pérdida de información, la compañía considerará acciones legales contra el tercero. La compañía tomará las medidas apropiadas para remediar cualquier incumplimiento de esta política y sus

procedimientos y lineamientos asociados a través de los acuerdos contractuales pertinentes vigentes o de otro modo a través de procesos legales. En el caso de un colaborador, las infracciones serán investigadas bajo el procedimiento disciplinario de la compañía y progresarán según corresponda.

10. DOCUMENTACIÓN RELACIONADA

- Política de ciberseguridad
- Política de protección de datos personales

ANEXO A

ANEXO B

ANEXO C

ANEXO D

APROBADO POR

Instancia de aprobación: Comité Estratégico de Ciberseguridad

Dueño de la política: Comité táctico de ciberseguridad.

CONTROL DE VERSIÓN

No. Rev.	Capítulo	Fecha	Descripción
V_001	Todos	Octubre de 2023	Emisión Inicial